

[Bài đọc] Cấu hình SecurityFilterChain tùy chỉnh

1. SecurityFilterChain

- **SecurityFilterChain** là một thành phần cốt lõi trong Spring Security, chịu trách nhiệm xác định các quy tắc bảo mật cho các yêu cầu HTTP.
- Mỗi **SecurityFilterChain** định nghĩa một tập hợp các bộ lọc (filters) được áp dụng theo thứ tự để xử lý yêu cầu, bao gồm xác thực, phân quyền, và các biện pháp bảo mật khác.
- Trong Spring Boot, **SecurityFilterChain** được cấu hình thông qua phương thức **@Bean** trong một class cấu hình sử dụng **@EnableWebSecurity**.

2. Cấu hình SecurityFilterChain

- Sử dụng **@Configuration** và **@EnableWebSecurity** để tùy chỉnh **SecurityFilterChain**:

```
public SecurityFilterChain securityFilterChain(HttpSecurity http) throws Exception {
    http.csrf(AbstractHttpConfigurer::disable)
        .cors(cors -> cors.configurationSource(corsConfigurationSource()))
        .sessionManagement(session -> session.sessionCreationPolicy(SessionCreationPolicy.STATELESS))
        .authorizeHttpRequests(auth -> {
            auth.requestMatchers(HttpMethod.GET, Endpoint.V1.Category.PREFIX + CATCH_ALL_WILDCARD).permitAll()
                .requestMatchers(HttpMethod.GET, Endpoint.V1.Product.PREFIX + CATCH_ALL_WILDCARD).permitAll()
                .requestMatchers(HttpMethod.GET, Endpoint.V1.Variant.PREFIX + CATCH_ALL_WILDCARD).permitAll()
                .requestMatchers("@ /v3/api-docs/**", @ "/swagger-ui/**", @ "/swagger-ui.html").permitAll()
                .requestMatchers(Endpoint.V1.Order.MOVE_TO_NEXT_STATUS + CATCH_ALL_WILDCARD).hasRole("ADMIN")
                .requestMatchers(Endpoint.V1.Category.PREFIX + CATCH_ALL_WILDCARD).hasRole("ADMIN")
                .requestMatchers(Endpoint.V1.Product.PREFIX + CATCH_ALL_WILDCARD).hasRole("ADMIN")
                .requestMatchers(Endpoint.V1.Variant.PREFIX + CATCH_ALL_WILDCARD).hasRole("ADMIN")
                .requestMatchers(Endpoint.V1.Cart.PREFIX + CATCH_ALL_WILDCARD).authenticated()
                .requestMatchers(Endpoint.V1.Address.PREFIX + CATCH_ALL_WILDCARD).authenticated()
                .requestMatchers(Endpoint.V1.Order.PREFIX + CATCH_ALL_WILDCARD).authenticated()
                .requestMatchers(Endpoint.V1.Payment.PREFIX + CATCH_ALL_WILDCARD).authenticated()
                .requestMatchers(CATCH_ALL_WILDCARD).permitAll()
        })
        .authenticationProvider(authenticationProvider);

    http.addFilterBefore(authTokenFilter, UsernamePasswordAuthenticationFilter.class);

    return http.build();
}
```

Giải thích:

Cấu hình	Ý nghĩa
----------	---------

<code>requestMatchers()</code>	Xác định URL pattern
<code>hasRole("ROLE_NAME")</code>	Chỉ người có vai trò tương ứng mới được truy cập
<code>permitAll()</code>	Cho phép truy cập không cần đăng nhập
<code>authenticated()</code>	Yêu cầu phải đăng nhập mới được truy cập